

GrassR00tz 2026

GOVERNANCE THAT GROWS WITH YOUR AI

Resilient AI Governance

June 4, 2026

Thomas Freeman

CISSP, C|CISO, GPEN, GCIA, GCIH, GCWN

DIRECTOR

- Leads CISO Advisory services
- 25+ years of IT and cybersecurity experience
- 20+ years in higher education



It fit on the day you bought it.

The jacket

Fits perfectly on day one. Six months later — the fit is gone.

AI governance today

Written for the AI we have. Then the AI changes shape, and the governance splits at the seams.

Most AI governance is bought off the rack — one size, shipped rigid. It fits the AI we have on the day we write it.



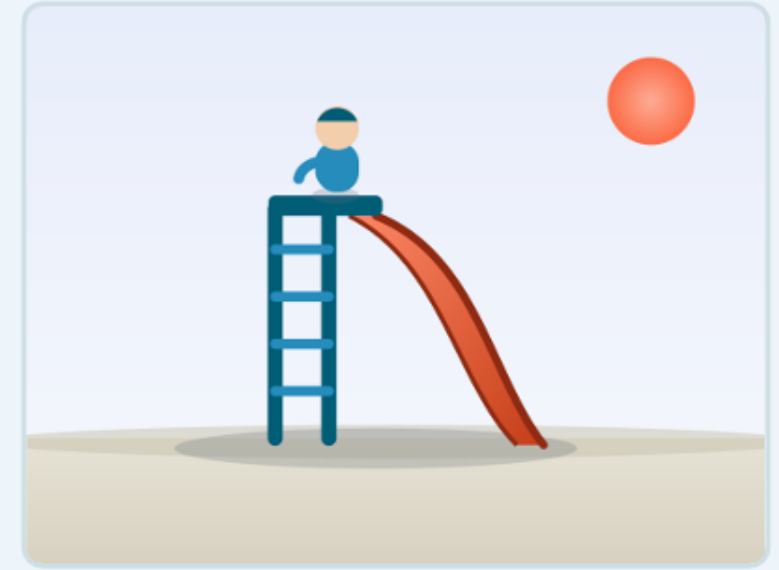
The premise: Different Domains require Different Responses

Clear

Sense → Categorize → Respond

BEST PRACTICE · FORMERLY "OBVIOUS / SIMPLE" · A *SINGLE SLIDE*

Cause and effect are obvious to everyone. Recognize the category and apply the known rule. There is one right answer.



EVERYDAY

Following a familiar recipe for spaghetti.

IR

A phishing report that matches a known pattern; run the playbook.

PARENTING

Bedtime routine; the same steps work every night.

AI GOV

Applying a settled acceptable-use rule to a clear-cut request.

IT / SEC

A password-reset ticket; a documented runbook step.

The premise: Different Domains require Different Responses

Complicated

Sense → Analyze → Respond

GOOD PRACTICE · *A BIG PLAY STRUCTURE*

A knowable answer that needs expertise to find. Experts may reasonably disagree on the route; there is more than one good way.



EVERYDAY	Baking a soufflé; hard, but a skilled cook knows how.
IR	Forensic analysis of a known malware family; methodical, expert-led.
PARENTING	Helping with calculus homework; a hard but solvable problem.
AI GOV	Building a model risk assessment to an established standard.
IT / SEC	Diagnosing why a server cluster is slow; a complex audit.

The premise: Different Domains require Different Responses

Complex

Probe → Sense → Respond

EMERGENT PRACTICE · *KIDS AT RECESS*

No right answer up front. Run a small, safe-to-fail experiment, watch what emerges, then amplify what works and dampen what doesn't.

EVERYDAY	Hosting a party; you set conditions but cannot script how it unfolds.
IR	Hunting a novel adversary; you test hypotheses and follow what you find.
PARENTING	Raising a teen; you shape values, you cannot dictate the outcome.
AI GOV	Governing emergent model behavior; pilot, monitor, adjust policy.
IT / SEC	Shifting a team's security culture; rolling out a new way of working.



The premise: Different Domains require Different Responses

Chaotic

Act → Sense → Respond

NOVEL PRACTICE • AN INJURY ON THE PLAYGROUND

No time to analyze, no stable patterns. Act immediately to stabilize, then assess. The goal is to get back to a domain where you can think.



EVERYDAY

A grease fire on the stove; you act first and reason later.

IR

Active ransomware detonating; isolate and contain now, investigate later.

PARENTING

A child is hurt; you respond instantly, then sort out what happened.

AI GOV

A model causing live harm; pull it offline first, root-cause after.

IT / SEC

A major outage or active breach in progress.

Resilient AI Governance is built in three steps.

1

Build

A foundation that holds its shape

2

Determine

The domain of each new AI
implementation

3

Leave room in the seams

For the AI that is coming

Take Note: We usually govern from our comfort domain.

The Compliance Leader

Writes a policy and feels finished.

The Engineer

Treats governance as one more system to analyze.

Both are skilled. Both reach for the tool that made them successful — whether or not the AI in front of them fits that tool.



The danger:
comfortable tools
applied everywhere.



Meet Meridian Health Logistics.

- Mid-market medical logistics company
- Moves medical supplies across facilities
- Touches PHI, PII, and payment data
- Stakes are real. Regulators are watching.

 AI did not arrive in one clean decision. It came in through four different AI systems.



Four different AI systems

1

Vendor Chatbot

Answering customer service questions

2

Internal Forecast Model

Data team built to predict supply demand

3

AI-Assisted Development

Developers shipping features built largely with AI

4

The Unplanned Moment

When one of these systems does something nobody planned for

Before we determine a single AI use case, we lay a foundation.

This is the part of the jacket that holds its shape no matter how the AI changes.

Get this right once, and it covers the majority of your AI risk — without touching a single specific use case.

The Shoulders

Structure that bears the load

The Lining

Invisible but essential protection

The Load-Bearing Seams

What holds everything together under pressure

The foundation. What are the basics that are needed for all AI solutions?

Data Classification

You cannot govern AI without knowing what data it can touch.

Data Protections

Controls that travel with the data, not just around it.

Vendor Risk Management

Your vendor review is now an AI discovery process.

AI Charter

One page. How the org will — and will not — use AI.

Acceptable use, roles and accountability, training, and intake all hang off these pillars.

Most of this is stable. It should not change much no matter how AI evolves.

Four questions to determine the domain:

The foundation covers everything known and ordered.
We can build a heatmap from the questions to find
what it does not cover.

- ① A tailor glances at cloth and knows how much work it will take.
We can do the same with any AI implementation.

1

Autonomy

Does it only inform, or
does it act?

2

Explainability

Can you trace why it
produced an output?

3

Adaptivity

Does it change after
deployment?

4

Reversibility

If it goes wrong, can you
cleanly undo it?

How the heatmap score relates to a domain.

Total	Domain	Governance approach
4 – 6	Clear	Foundation alone is sufficient
7 – 10	Complicated	Add expert-driven controls
11 – 13	Complex	Run a safe-to-fail probe
14 – 16	Chaotic	Pre-decided authority and a kill switch

✓ CLEAR DOMAIN

Score 1: The vendor chatbot.



Narrow Scope

Order status only. Vendor product, contract and SLA in place.



Verdict: Clear

Informs only. Traceable. Static. Clean undo.

Foundation already covers it.

- Data classification: no PHI
- Vendor risk reviewed
- Charter's acceptable-use line applies



One new line added: **reassess if the vendor adds new capabilities.** That single line is the seam allowance.

Score 2: The demand-forecasting model.

Built by the data team. Outputs inform purchasing. Retrains quarterly.

Autonomy

Informs only

Explainability

Mostly traceable

Adaptivity

Periodic retraining

Reversibility

Recoverable

Complicated cut — four moves:

01

Model documentation

Sources, intended use, known limitations

02

Validation & bias testing

Against a defined acceptable range

03

Drift monitoring

Named technical owner

04

Human review gate

Before forecasts drive purchasing



<> COMPLEX DOMAIN

Score 3: AI-assisted development.

Developers prompt. AI generates.
Does anyone fully see what is in the codebase?



The thing changing is not the code.
It is **human behavior** in a **social system** — and behavior shifts in response to the controls you place on it.

Why a hard rule fails here:

Disciplined teams

Slow to a crawl under strict review rules.

Fast teams

Quietly route around you. The behavior goes underground where you cannot see it.

COMPLEX → PROBE, NOT POLICY

Run a safe-to-fail probe.

01

Pick two teams

Lightweight AI-code guideline plus tooling that makes the safe path the fast path

03

Review in weeks, not annually

Let governance evolve from what you observe

02

Instrument the behavior

Capture what gets routed around and where risk shows up

04

Channel the behavior

Make the governed way the easy way



Notice what I did not do. I did not write the final rule.

Score 4: The agentic logistics AI reroutes shipments overnight.

A pattern it learned. Temperature-sensitive medical supplies arrive at the wrong facility.

⊗ The IR runbook has steps for ransomware and breach. But it **does not have steps** for "the AI did something we cannot explain."

AI IR differs from classic IR:

- Cannot fully explain why the model acted
- Cannot roll it back like a bad deploy
- Blast radius is data and decisions, not just systems
- Containment may mean pulling a model the business now depends on



You cannot tailor in a fire.



Kill Switch

Defined and tested before deployment



Standing Authority

Named individual. No prior approval needed to disable.



AI-Specific IR Playbook

Stabilize. Isolate model. Preserve inputs and outputs.



Pre-agreed Business Decision

Taking a model offline: decided before deployment, not during crisis.

The extra seam allowance for Chaotic is the **authority** you grant **before the smoke**.



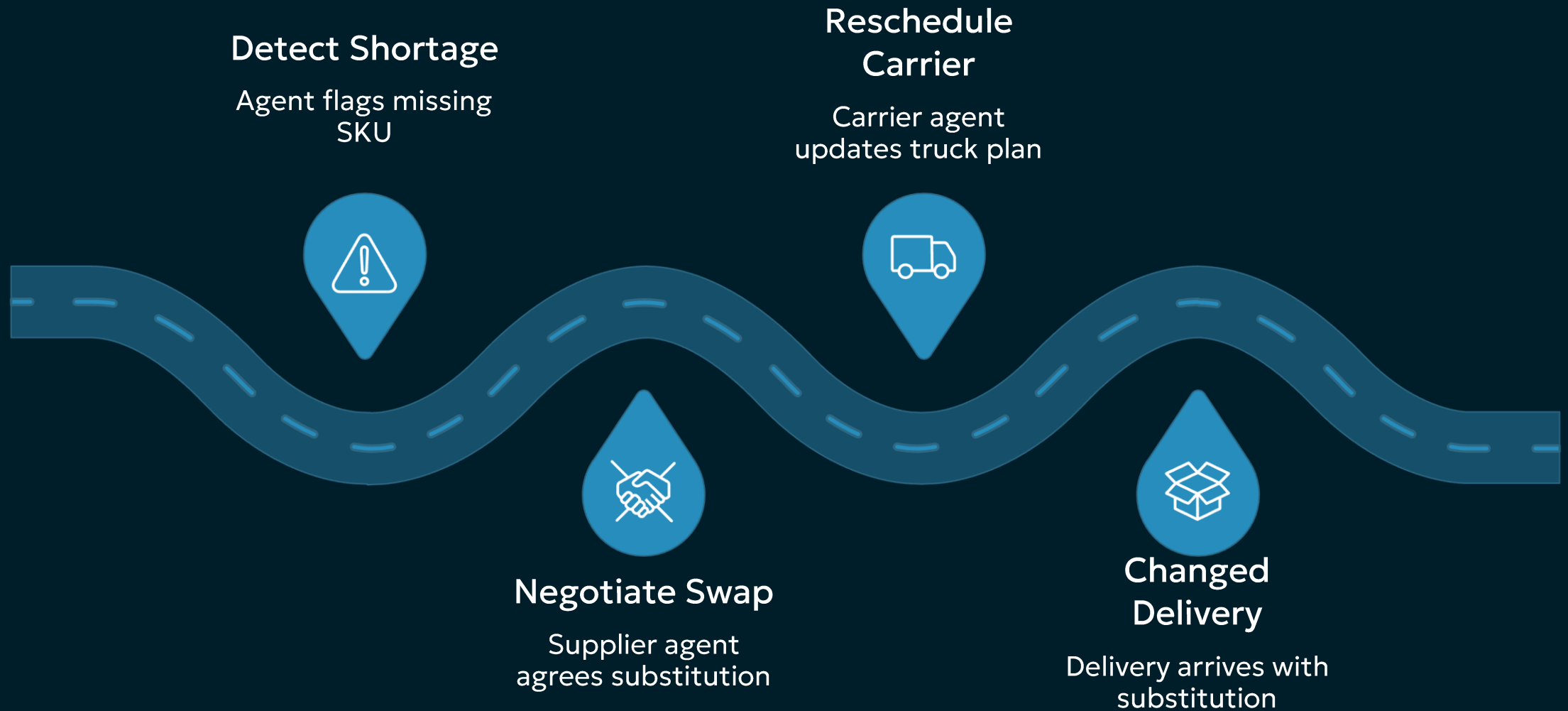
Agentic AI is the present, not the next thing.

Meridian's logistics AI can already act.
Your tools may already be able to:

- Book the refund
- Merge the pull request
- Rerun the pipeline

 The next evolution is not "AI that acts." It is AI that acts by talking to another companies' AI. And...who can predict where this goes next?

Meridian's agent talks to the supplier's agent.



*Every agent did something locally reasonable and governed.
Its the chain that nobody owned or governed.*

Re-run the four characteristics.

Autonomy

Compounds. Your agent's action triggers their agent's action — no human gate.

Explainability

Drops hard. The decision lives across three companies' systems.

Reversibility

Drops. The substitution shipped. The truck moved.

Verdict

The score moves from Complicated into **Chaotic**.
The governance must move with it.



A properly tailored jacket does not have to be thrown away.

Kill Switch Extends

Pre-assigned authority stretches to cover agent-to-agent behavior.

Vendor Risk Stretches

Now covers agent-to-agent data sharing at machine speed.

Data Classification in the foundation Holds

Still applies — now at the speed and scale of automated decisions.

Resilient governance bends as the AI grows, because we built it **knowing the AI would grow.**

Example Policy



Document control

Field	Value
Policy owner	[Policy Owner: e.g., CISO or designated AI governance lead]
Approved by	[AI Governance Committee]
Version	0.4 (example skeleton)
Effective date	[Effective Date]
Classification	Internal
Next scheduled review	[Review Date: at least annual]

Revision history

Version	Date	Author	Summary of change
0.1	[Date]	[Author]	Initial example skeleton; foundation and domain requirements seeded.

1. Purpose

- 1.1 This policy establishes how [Organization] governs the use of artificial intelligence across its lifecycle, from selection and development through operation and retirement.
- 1.2 The chartered purpose of this policy is to ensure that every AI implementation is governed in a manner matched to its actual behavior, and that governance remains effective as both the organization’s use of AI and AI technology continue to change. The policy is built in two layers: a stable foundation that applies to all AI, and domain-based requirements that an implementation inherits according to how it behaves.
- 1.3 This policy supports and operates under the [Organization] AI Charter. Where the Charter states principles, this policy states the requirements that put those principles into effect.

2. Scope

- 2.1 This policy applies to all AI implementations used by [Organization], whether built in-house, procured, or enabled as a feature within an existing tool or service.
- 2.2 This policy applies regardless of autonomy level, from systems that only inform a human decision through systems that act independently.

Example Register

	A	B	C	D	E	F	G	H	I	J
1	AI Registry Single source of truth for AI tools									
2	Score each row 1 (ordered) to 4 (unordered). Cells color as you type; Domain and the recommended move calculate automatically.									
3	Domain legend:	Clear	Complicated	Complex	Chaotic					
4										
5	AI Implementation	Vendor	URL	Autonomy	Explainability	Adaptivity	Reversibility	Total	Domain	Recommended Governance Move
6	Vendor chatbot (order status)	[Vendor name]	[vendor portal URL]	1	2	2	1	6	Clear	Foundation covers it. Confirm classification, vendor review, charter; add a reassessment trigger.
7	Demand-forecasting model (internal)	Internal	[internal app URL]	2	2	3	2	9	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
8	AI coding assistant (development)	[Vendor name]	[tool URL]	3	3	3	3	12	Complex	Run a safe-to-fail probe: pilot teams, lightweight guideline, instrument behavior, short feedback loop.
9	Agentic logistics AI (auto-reroute)	Internal	[internal app URL]	4	4	4	4	16	Chaotic	Pre-decide authority: kill switch, named decision-maker, AI-specific IR playbook, preserve inputs and outputs.
10	Claude.ai (chat assistant)	Anthropic	https://claude.ai	1	2	3	1	7	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
11	Claude Cowork	Anthropic	https://claude.ai	3	2	3	2	10	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
12	Claude Code	Anthropic	https://claude.com	3	3	3	2	11	Complex	Run a safe-to-fail probe: pilot teams, lightweight guideline, instrument behavior, short feedback loop.
13	Salesforce with Einstein/AgentForce	Salesforce	[tenant URL]	3	2	3	2	10	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
14	Microsoft 365 Copilot	Microsoft	[tenant URL]	2	2	3	1	8	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
15	GitHub Copilot	GitHub/Microsoft	https://github.com/copilot	2	2	3	2	9	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
16	ChatGPT Enterprise	OpenAI	https://chatgpt.com	1	2	3	1	7	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.
17	Zoom AI Companion	Zoom	[tenant URL]	2	2	3	1	8	Complicated	Add expert controls: documentation, validation/bias testing, drift monitoring, named owner, human review gate.

Same method. Every time.



Each time: **Re-determine the domain. Re-score.**

You will never write the perfect policy ahead of time. But you can build a way to **diagnose what is in front of you**, a foundation that holds, and include enough room in the policy seams to expand appropriately.

Tomorrow morning

01

Pick one AI

Name one AI in your organization that is about to change shape.

03

Route to a domain

Clear, Complicated, Complex, or Chaotic?

02

Ask the four questions

Autonomous? Explainable? Adaptive? Reversible?

04

Diagnose first. Then cut.

Apply only the governance the domain requires.

Give your AI a jacket it won't outgrow.

Thank you.

Handouts available at:

<https://github.com/zoeified/resilient-ai-gov>





TODAY'S PRESENTER

Thomas Freeman, Director
CISSP, C|CISO, GPEN, GCIA, GCIH, GCWN
Thomas.Freeman@ghostscale.com
262.527.4746

<https://github.com/zoeified/resilient-ai-gov>

GHOSTSCALE.COM

